

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5 TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I p.paneendra (192321072) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: p.paneendra

Annexure A
Industry Problem-Solving Task

1. A multinational enterprise is deploying IPsec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
 - B. Design packet flow with appropriate IPsec modes (transport/tunnel)
 - C. Justify protocol selection for different data types
 - D. Evaluate performance vs security trade-offs
-
2. An organization faces frequent key management issues in its IPsec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
 - B. Design an automated key management mechanism (e.g., IKE-based)
 - C. Propose a strategy for key renewal and revocation
 - D. Evaluate scalability and fault tolerance
-
3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification

D. Design a high-level implementation workflow

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

A. Identify limitations of existing filtering techniques

B. Analyze email headers for spoofing indicators

C. Design an improved detection model (rule-based or ML-based)

D. Evaluate effectiveness and false positive handling

5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

A. Identify potential certificate-related vulnerabilities

B. Analyze trust chain and validation process

C. Propose secure certificate storage and management practices D.

Recommend improvements for user awareness and system configuration

1. IPSec Deployment for Multinational Branch Offices

A. Identify which traffic requires AH, ESP, or both

Authentication Header (AH) provides:

- Data integrity.
- Data-origin authentication.
- Protection against replay attacks.
- It does not provide confidentiality, so the actual data remains visible.

Encapsulating Security Payload (ESP) provides:

- Confidentiality through encryption.
- Data integrity and authentication when authentication is enabled.
- Replay protection.
- ESP is generally preferred for modern VPN deployments.

For branch-office communication, ESP should be the primary protocol because business traffic such as financial data, employee information, database traffic, and internal applications requires confidentiality as well as integrity.

AH can be used when authentication and integrity are required but encryption is unnecessary. However, AH is rarely used in practical VPN deployments because ESP can provide both encryption and authentication.

Using both AH and ESP is possible when additional authentication protection is required, but it introduces extra processing and packet overhead and is generally unnecessary when authenticated ESP is properly configured.

B. Packet flow and IPSec modes

For branch-to-branch communication, tunnel mode is the most appropriate.

The packet flow is:

Original IP Packet → ESP Encryption + Authentication → New IP Header → Internet → Remove New Header → ESP Decryption + Verification → Original IP Packet

For example:

Branch A → VPN Gateway A → Internet → VPN Gateway B → Branch B

The original packet contains the private IP addresses of the communicating systems. Tunnel mode encrypts and encapsulates the original IP packet and adds a new IP header containing the VPN gateway addresses.

Transport mode can be used for host-to-host communication, where individual computers directly establish IPSec protection.

C. Protocol selection for different data types

Highly sensitive information such as:

- Financial transactions
- Customer records
- Employee information
- Database communication
- Internal application traffic

should use ESP with encryption and authentication.

Less sensitive traffic that only requires integrity and authentication could theoretically use AH, but authenticated ESP is normally simpler and more flexible.

For branch-to-branch VPNs, ESP tunnel mode is the recommended configuration because it

protects the complete original IP packet.

D. Performance vs. security trade-offs

AH has lower processing overhead because it does not perform encryption. However, it does not provide confidentiality.

ESP requires encryption and authentication, so it consumes more CPU resources and adds some packet overhead. Modern hardware and VPN gateways generally handle this efficiently.

Therefore, the small performance cost of ESP is usually acceptable because the security benefits are much greater. For a multinational enterprise, ESP tunnel mode provides the best balance between security, scalability, and performance.

2. IPSec Security Association and Key Management

A. Current SA lifecycle issues

A Security Association (SA) contains parameters such as:

- Encryption algorithm.
- Authentication algorithm.
- Encryption keys.
- Authentication keys.
- Lifetime.
- SPI (Security Parameter Index).

Common SA problems include:

- Expired keys.
- Mismatched encryption algorithms.

- Different security parameters at both endpoints.
- Incorrect SPI values.
- Manual key configuration errors.
- Failure to renew keys before expiration.
- Old SAs remaining active after a new SA is created.

These problems can cause communication failures and security weaknesses.

B. Automated key management using IKE

The organization should use Internet Key Exchange (IKE) to automate IPSec key management.

The general process is:

IPSec Peer A → IKE Negotiation → Authentication → Security Parameter Agreement → Key Exchange → IPSec SA Creation → Secure Communication

IKE automatically negotiates:

- Encryption algorithms.
- Authentication methods.
- Diffie-Hellman parameters.
- Session keys.
- SA lifetime.

Instead of manually entering keys on every VPN device, administrators configure compatible IKE policies and allow the devices to negotiate keys automatically.

For enterprise environments, IKEv2 is generally preferred because it provides improved reliability, mobility support, and efficient SA management.

C. Key renewal and revocation

Keys should have a predefined lifetime. Before the lifetime expires, IKE should automatically

negotiate fresh keys.

A suitable process is:

Active SA → Lifetime Approaches → New Key Negotiation → New SA Created → Traffic Moves to New SA → Old SA Removed

If a key or device is compromised, the corresponding credentials should be revoked immediately.

Certificate-based authentication can be combined with a PKI (Public Key Infrastructure). Revoked certificates can be recorded using appropriate certificate revocation mechanisms.

D. Scalability and fault tolerance

For a large enterprise with many branches, centralized key-management policies should be used.

Scalability can be improved through:

- IKEv2 automation.
- Certificate-based authentication.
- Centralized PKI.
- Automated certificate renewal.
- Standardized IPSec policies.
- Redundant VPN gateways.

Fault tolerance can be improved by deploying multiple VPN gateways and redundant network paths.

If one gateway fails, another gateway can establish the required IKE and IPSec SAs. Automated negotiation also reduces dependence on manual administrator intervention.

Thus, IKEv2 combined with PKI, automatic rekeying, and redundant gateways provides an efficient and scalable solution.

3. PGP vs S/MIME for Secure Financial Email

A. Real-world deployment comparison

PGP (Pretty Good Privacy) provides email encryption and digital signatures using public-key cryptography.

It is commonly suitable for:

- Individual users.
- Technical organizations.
- Open or decentralized communication environments.
- Users who want greater control over their keys.

S/MIME (Secure/Multipurpose Internet Mail Extensions) uses digital certificates to provide email encryption and digital signatures.

It is particularly suitable for:

- Banks.
- Financial institutions.
- Government organizations.
- Large enterprises.
- Organizations using centrally managed email systems.

For an enterprise, S/MIME is generally easier to integrate with existing corporate email infrastructure.

B. Key management and trust models

PGP commonly uses a web-of-trust model. Users can verify and sign each other's public keys. This provides flexibility but can become difficult to manage in a large organization.

S/MIME uses a certificate-based trust model. Certificates are issued by trusted Certificate Authorities (CAs).

The S/MIME trust process is:

User → Digital Certificate → Certificate Authority → Trust Validation

The organization can centrally manage certificates, renewal, revocation, and policies.

C. Recommended solution

For a financial services company, S/MIME is generally recommended.

The main reasons are:

- Better enterprise integration.
- Centralized certificate management.
- Easier administration.
- Strong identity verification.
- Integration with corporate email systems.
- Support for digital signatures.
- Better suitability for regulatory and organizational requirements.

PGP can still be useful when communication occurs with external parties who already use PGP.

D. High-level implementation workflow

The implementation can follow these steps:

1. Establish PKI

The organization establishes or selects a trusted Certificate Authority.

2. Issue certificates

Certificates are issued to employees and authorized users.

3. Configure email clients

Corporate email applications are configured to use S/MIME.

4. Send secure email

The sender digitally signs the email and encrypts it using the recipient's public certificate.

5. Recipient verification

The recipient's email client verifies the digital signature and decrypts the message using the recipient's private key.

6. Certificate management

Certificates are periodically renewed and revoked when necessary.

Overall, S/MIME provides a more manageable enterprise solution for sensitive financial email communication.

4. Advanced Spam and Phishing Detection

A. Limitations of existing filtering techniques

Basic spam filters often depend on:

- Simple keyword matching.
- Blacklists.
- Sender addresses.
- Fixed rules.

- Known spam signatures.

These approaches have limitations because attackers continuously change:

- Email addresses.
- Domain names.
- Message content.
- URLs.
- Formatting.
- Attachment names.

Attackers can also make phishing emails appear similar to legitimate corporate messages.

Therefore, relying only on basic filtering can result in both false negatives and false positives.

B. Email header analysis

Email headers provide important information about the origin and delivery path of a message.

The system should examine:

- From address
- Reply-To address
- Return-Path
- Received headers
- Message-ID
- Date
- Authentication results
- SPF
- DKIM
- DMARC

For example, if the visible sender claims to be a bank but the actual sending domain is unrelated,

the message should receive a high risk score.

The system should also detect:

- SPF failures.
- DKIM failures.
- DMARC failures.
- Suspicious IP addresses.
- Domain mismatches.
- Unusual mail-routing paths.

C. Improved detection model

A hybrid rule-based and machine-learning model can provide better results.

First, rule-based analysis can identify obvious threats.

Example:

Header Analysis + URL Analysis + Sender Reputation + Attachment Analysis → Risk Score

Then machine learning can analyze:

- Email text.
- Writing patterns.
- Sender behavior.
- URL characteristics.
- Message structure.
- Historical communication patterns.

The final system can classify messages as:

Legitimate → Suspicious → Spam → Phishing/Malicious

For example:

Email → Header Analysis → Content Analysis → URL/Attachment Analysis → ML
Classification → Risk Score → Final Action

D. Effectiveness and false-positive handling

The system should not automatically delete every suspicious email.

A better approach is:

- Low risk: Deliver normally.
- Medium risk: Place in spam/quarantine.
- High risk: Block or quarantine.
- Confirmed malicious: Reject and report.

False positives can be reduced by:

- Maintaining trusted sender lists.
- Learning normal communication patterns.
- Combining multiple detection features.
- Allowing users to report incorrect classifications.
- Periodically retraining the ML model.

The effectiveness of the system can be measured using precision, recall, false-positive rate, and detection rate.

A hybrid approach provides stronger protection than relying only on traditional spam rules.

5. Secure Certificate Management in S/MIME

A. Potential certificate-related vulnerabilities

Improper certificate handling can cause several security problems:

- Expired certificates.
- Revoked certificates still being trusted.
- Self-signed certificates being accepted without verification.
- Incorrect certificate-to-user mapping.
- Weak cryptographic algorithms.
- Private keys being exposed.
- Improper certificate storage.
- Failure to verify the Certificate Authority.
- Incorrect certificate chain validation.
- Failure to check certificate validity periods.

If an attacker obtains a user's private key, they may be able to decrypt messages or create fraudulent digital signatures.

B. Trust chain and validation

S/MIME certificates normally follow a hierarchy:

Root CA → Intermediate CA → User Certificate

The email client should verify:

1. Certificate is issued by a trusted CA.
2. Certificate has not expired.
3. Certificate has not been revoked.
4. Certificate chain leads to a trusted root.
5. Certificate identity matches the sender or recipient.
6. Appropriate key usage is permitted.
7. Cryptographic algorithms are sufficiently strong.

For example:

User Certificate → Intermediate CA → Root CA → Trusted

If any part of the chain cannot be trusted, the certificate should not automatically be accepted.

C. Secure certificate storage and management

Private keys should be protected using:

- Strong passwords.
- Secure key stores.
- Hardware security modules where appropriate.
- Access control.
- Encryption at rest.
- Regular backups with appropriate protection.

Organizations should maintain a centralized certificate-management process for:

- Certificate issuance.
- Renewal.
- Revocation.
- Replacement.
- Monitoring.
- Expiration alerts.

Private keys should never be shared between users.

When an employee leaves the organization, their certificate and associated credentials should be properly revoked according to organizational policy.

D. User awareness and system configuration

Users should be trained to recognize certificate warnings and should not simply ignore them.

They should understand:

- Why certificate warnings appear.
- How to verify trusted recipients.
- Why private keys must remain confidential.
- Why suspicious email signatures should be reported.

Administrators should configure email clients to:

- Validate certificate chains.
- Check expiration.
- Check revocation status.
- Trust only approved CAs.
- Use strong cryptographic algorithms.
- Generate appropriate alerts for invalid certificates.

Regular audits should also be performed to identify expired, weak, duplicated, or improperly configured certificates.

Overall, secure S/MIME requires both strong technical certificate management and proper user awareness.